

Information Security Policy

This policy defines Saudi EXIM Bank's approach to information security, establishing the framework, roles, and controls to protect information assets, ensure regulatory compliance, and maintain confidentiality, integrity, and availability across all business operations.

G-R-C Ops

Version	Approved By	Owner	Date Last Updated	Review Frequency	Next Review	Comments
1.0	Board of Directors	CISO	-	Every 6 months	1 st – July – 2026	

Contents

Policy Purpose	2
Policy Scope	2
Management Commitment.....	2
Roles & Responsibilities	2
Related ISMS Policies	3
Information Security Objectives	4
Policy Statements	4
1. Training and Awareness	4
2. Physical Security.....	4
3. Oral Communications.....	4
4. Third-Party Security	5
5. Employment Screening	5
6. Restricting Unauthorised Access	5
7. Appropriate Use of Security Credentials	5
8. Cryptographic Controls	5
Information Classifications	6
1. Top Secret Information.....	6
2. Secret Information.....	6
3. Restricted Information	7
4. Public Information	8
Breaches of Security	8
Associated Policies and Documents	8
Monitoring and Filtering	8

Policy Purpose

This policy establishes Saudi EXIM Bank's commitment to protecting information assets and implementing a formal Information Security Management System (ISMS).

The Bank is committed to safeguarding the confidentiality, integrity, and availability of information and ensuring compliance with applicable legal, regulatory, and contractual obligations.

Policy Scope

This policy applies to:

- All employees, contractors, and third parties
- All business units and support functions
- All physical locations and remote working environments
- All information assets, systems, applications, infrastructure, and outsourced service

Management Commitment

The Board of Directors and Executive Management formally commit to:

- Establishing, implementing, maintaining, and continually improving an ISMS aligned with ISO/IEC 27001:2022
- Integrating information security into business processes and strategic planning
- Providing adequate resources to support information security objectives
- Defining and reviewing the Bank's risk appetite
- Ensuring accountability for information security performance

Roles & Responsibilities

Board of Directors:

- Approve overall cybersecurity strategy and ISMS framework
- Define risk appetite, approve security policies, and allocate resources
- Receive regular ISMS performance reports and ensure accountability

Chief Information Security Officer (CISO):

- Develop and implement enterprise-wide cybersecurity strategy
- Lead ISMS implementation and continuous improvement
- Oversee risk management, incident response, regulatory compliance, and vendor security

Information Security Manager (ISMS Manager):

- Manage day-to-day ISMS operations
- Conduct risk assessments and enforce ISMS adherence
- Promote security awareness and training programs

IT / Security Operations Team:

- Monitor networks, endpoints, and applications for threats
- Investigate and respond to incidents, manage vulnerabilities, and enforce technical controls
- Support access management, backup, and recovery

Internal Audit / Compliance Team:

- Conduct audits, ensure regulatory compliance, and report findings
- Recommend corrective actions to enhance ISMS and operational security

Precurment Vendor Team:

- Assess and monitor vendor security posture
- Enforce contractual security clauses and incident reporting
- Coordinate vendor-related security incidents

Risk Management Department

- Identify, assess, and monitor organizational and information security risks, maintaining an up-to-date risk register.
- Recommend and oversee risk treatment strategies, ensuring alignment with the Bank's risk appetite, ISMS policies, and regulatory requirements.
- Provide regular risk reports to management and the Board, escalate critical risks, and contribute to lessons-learned reviews to enhance risk management practices.

Security Team

- Implement, monitor, and maintain technical security controls, monitor emerging threats, and provide actionable intelligence to IT/SOC and Risk Management teams.
- Assist in detecting, containing, and remediating security incidents, and support audits by enforcing policies and providing required evidence.
- Manage access provisioning and privilege reviews according to least privilege principles, and contribute to security awareness and training initiatives.

All Staff:

- Comply with policies and procedures
- Report security breaches promptly
- Request policy exceptions via IT Helpdesk

Reference: See ISMS Roles & Responsibilities Document for detailed RACI matrix.

Related ISMS Policies

To ensure comprehensive information security management, detailed policies that support and complement this Information Security Policy have been established.

Employees, contractors, and other stakeholders are required to familiarise themselves with these policies and adhere to their guidelines.

The related policies include:

Policy Name	Description
Information Security Policy	Overarching policy for ISMS governance and reference to supporting policies
Access Control Policy	Controls access to systems based on roles and least privilege
Acceptable Use Policy	Defines acceptable and prohibited use of Bank IT assets
Vendor Security Policy	Security requirements for third-party engagement

Data Classification Policy	Framework for classifying and handling information assets
Incident Response Policy	Structured approach for detecting, reporting, and responding to security incidents
Business Continuity Policy	Framework to maintain critical operations during disruptions
Backup & Recovery Policy	Requirements for data backup, retention, testing, and restoration
Other supporting policies	BYOD, Mobile Device, Password, Cloud Services, Secure Development, Remote Working Policies

Information Security Objectives

- Implement and maintain ISMS framework in alignment with ISO/IEC 27001:2022
- Conduct risk assessments and manage risk treatment plans
- Deliver ongoing security awareness training to all staff
- Strengthen technical controls (MFA, EDR, vulnerability scanning, SOC monitoring)
- Ensure compliance with ISO 27001, PCI DSS, and applicable laws
- Achieve ISO 27001 certification by Q4 2026

Policy Statements

1. Training and Awareness

- 1.1 Induction and Role-Based Training:** All staff shall complete mandatory induction and role-based information security training prior to assuming their responsibilities
- 1.2 Ongoing Awareness:** Staff shall receive regular updates on emerging security threats, vulnerabilities, and changes to organizational policies.
- 1.3 Training Completion Targets:** At least 90% of all staff must complete security awareness training each quarter to ensure ongoing compliance and risk mitigation.
- 1.4 Role-Specific Scenario Training:** Staff shall participate in simulated exercises to reinforce practical understanding of threats.
- 1.5 Training Effectiveness Assessment:** Periodic testing and evaluations shall be conducted to measure understanding and effectiveness of training programs.
- 1.6 Continuous Improvement:** Training materials shall be reviewed and updated annually or when significant changes in threats, policies, or technologies occur.

2. Physical Security

- 2.1 Access Control:** Access to Bank facilities shall be controlled through the use of authorized swipe cards and keys.
- 2.2 Visitor Management:** All visitors must be escorted, and entry to restricted areas must be monitored at all times.
- 2.3 Credential Security:** Any lost or compromised access credentials must be reported immediately to the Security Team.
- 2.4 Security Patrols:** Regular security patrols shall be conducted to detect and prevent unauthorized access.
- 2.5 Secure Areas Identification:** Critical areas shall be clearly marked and restricted to authorized personnel only.
- 2.6 Incident Reporting:** Physical security must be reported immediately.

3. Oral Communications

- 3.1 Confidential Information Handling:** Staff should exercise caution when discussing confidential or sensitive information in public areas to prevent unauthorized disclosure.

- 3.2 Secure Meetings:** Confidential discussions must be conducted in secure, private areas.
- 3.3 Electronic Communication Awareness:** Staff shall avoid discussing sensitive information over unsecured phone lines or public networks.

4. Third-Party Security

- 4.1 Vendor Risk Assessments:** All vendors handling Bank data shall undergo formal risk assessments prior to engagement.
- 4.2 Confidentiality Agreements:** Vendors are required to sign confidentiality agreements to protect the Bank's sensitive information.
- 4.3 Third-Party Compliance:** Compliance with the Bank's security policies shall be enforced through contractual obligations and regular audits of third-party vendors
- 4.4 Third-Party Security Training:** Key vendor personnel shall receive training on the Bank's security requirements.
- 4.5 Termination Procedures:** Ensure secure offboarding for vendors, including revoking access and returning Bank assets.
- 4.6 Third-Party Incident Reporting:** Vendors must report security incidents affecting Bank data within a defined timeframe.

5. Employment Screening

- 5.1 Pre-Employment Screening:** Background checks shall be conducted for all employees and contractors prior to onboarding.
- 5.2 Periodic Re-screening:** Certain roles may require periodic background checks or security clearances.
- 5.3 Reference Checks:** Verification of professional and educational references shall be conducted.

6. Restricting Unauthorised Access

- 6.1 Access Control:** Access shall be granted based on the principle of least privilege.
- 6.2 Authorization for Sensitive Data:** Sharing of sensitive information requires explicit authorization from designated personnel.
- 6.3 Access Review:** Access rights shall be regularly reviewed and audited to ensure compliance with security policies.
- 6.4 Segregation of Duties:** Access shall be structured to prevent conflicts of interest and reduce risk of misuse.
- 6.5 Temporary Access Control:** Temporary access rights must be time-bound and revoked promptly.

7. Appropriate Use of Security Credentials

- 7.1 Credential Security:** Staff must protect their credentials and must not share them under any circumstances.
- 7.2 Multi-Factor Authentication:** Multi-factor authentication (MFA) shall be enabled wherever supported.
- 7.3 Password Management:** All passwords must be created, used, and managed in accordance with the Bank's Password Policy.
- 7.4 Account Lockout Policies:** Systems shall enforce account lockouts after repeated failed login attempts.
- 7.5 Credential Recovery:** Secure procedures for lost or compromised credentials shall be in place.

8. Cryptographic Controls

- 8.1 Cryptographic Key Management:** Procedures shall be maintained for the secure generation, storage, rotation, and destruction of cryptographic keys.

- 8.2 Encryption Standards Review:** Approved encryption algorithms and cryptographic standards shall be regularly reviewed to ensure continued effectiveness and compliance.
- 8.3 Key Usage Restrictions:** Cryptographic keys shall only be used for approved purposes.
- 8.4 Key Backup and Recovery:** Procedures shall ensure secure backup and recovery of cryptographic keys.
- 8.5 Audit and Logging:** All key management activities shall be logged for audit and compliance purposes.

Information Classifications

Information within Saudi EXIM Bank is classified based on sensitivity, business need, and regulatory requirements. Each classification defines handling requirements to ensure confidentiality, integrity, and availability.

1. Top Secret Information

Definition:

Information whose unauthorized disclosure, loss, or tampering could cause exceptionally grave operational, financial, reputational, or national impacts to the Bank, its customers, business partners, or critical infrastructure.

Access:

- Must be explicitly approved by the information owner and CISO.
- Restricted to personnel with the highest security clearance and a documented business need.

Examples:

- Critical incident response plans affecting national or sectoral operations
- Encryption keys controlling access to highly sensitive systems
- Strategic security architectures or classified financial data

Handling Guidance:

- **Encryption:** Encrypt at rest and in transit using approved NCA cryptographic standards.
- **Access Control:** Limit strictly to authorized personnel; implement role-based access.
- **Storage:** Secure physical and digital storage environments; controlled entry.
- **Data Transfer:** Use only secure, encrypted channels.
- **Destruction/Disposal:** Irreversibly destroy when no longer required; maintain logs of destruction.
- **Labelling:** All digital and physical copies must be clearly labeled “**Top Secret – Level**”.
- **Breach Protocol:** Immediately report any suspected or confirmed unauthorized access according to the Incident Response Policy.

2. Secret Information

Definition:

Information whose unauthorized disclosure could cause serious operational, financial, or reputational harm to the Bank, its customers, or business partners.

Access:

- Requires authorization from business owners and security management.
- Limited to personnel with a legitimate need-to-know.

Examples:

- Internal audit reports with sensitive findings
- Proprietary system or security designs
- Non-public partner agreements

Handling Guidance:

- **Encryption:** Encrypt at rest and in transit using approved cryptographic methods.
- **Access Control:** Limit strictly to authorized personnel; implement role-based access.
- **Storage:** Store in controlled systems with logging and monitoring.
- **Data Transfer:** Use secure, encrypted channels.
- **Destruction/Disposal:** Securely destroy when no longer required.
- **Labelling:** All information must be labelled “**Secret – Level**”.
- **Breach Protocol:** Immediately report any suspected or confirmed unauthorized access according to the Incident Response Policy.

3. Restricted Information

Definition:

Information whose unauthorized disclosure could cause limited operational, financial, or reputational harm. Default classification for data not explicitly marked Top Secret, Secret, or Public.

Access:

- Shared internally among employees and authorized contractors.
- External sharing requires written approval from the information owner.

Examples:

- Customer PII and internal communications
- Internal financial reports or operational data
- Change management documentation

Handling Guidance:

- **Encryption:** Encrypt in transit; at-rest encryption as per risk assessment.
- **Access Control:** Limit to employees and authorized contractors; do not share externally without approval.
- **Storage:** Store in secure, access-controlled systems.
- **Data Transfer:** Use internal systems only; encrypted transfer optional.
- **Destruction/Disposal:** Securely destroy when no longer required.
- **Labelling:** All information must be labelled “**Restricted – Level**”.
- **Breach Protocol:** Report suspected or confirmed disclosure incidents in line with the Incident Response Policy.

4. Public Information

Definition:

Information approved for public release by an authorized Bank representative. Disclosure outside the organization is permitted.

Access:

- No restriction on sharing; source information remains controlled internally.

Examples:

- Marketing materials, brochures, and social media content
- Website content and press releases

Handling Guidance:

- **Encryption:** Not required.
- **Access Control:** No restrictions; ensure the source version is protected internally.
- **Storage:** May be stored on multiple platforms without specific access controls.
- **Data Transfer:** Standard transmission; encryption not required.
- **Destruction/Disposal:** No formal controls required, though outdated materials should be retired.
- **Labelling:** Master copies should be labelled “**Public – Level**”.
- **Breach Protocol:** Not applicable.

Breaches of Security

- Report system security incidents to IT Helpdesk
- Report physical breaches to Office Manager/CPO
- Follow Incident Response Policy for major breaches
- Follow Data Protection Policy for personal data breaches

Associated Policies and Documents

The following policies support and provide additional context to this policy and responsibilities.

Policy	Description
Acceptable Use Policy	Guides staff on appropriate technology usage
Data Protection Policy	Protects personally identifiable information
Password Policy	Enforces password complexity and security
Mobile Phone / BYOD Policies	Guidelines for secure mobile and personal device usage
SaaS / Cloud Services Policy	Secure evaluation and onboarding of cloud applications
Access Control Policy	Management of system access rights
Supplier Security Policy	Third-party security requirements

Monitoring and Filtering

- Monitor IT systems to ensure security and compliance with laws
- Maintain logs and investigate incidents